Kriptográfia és biztonság 7.

MAC

Biztonság vs. Integritás

- biztonságos kommunikáció
  - Aliz üzenetet küld Bob-nak
  - nyílt kommunikációs csatornán
  - biztonság
  - **eszköz:** titkosítás

Biztonság vs. Integritás

- biztonságos kommunikáció
  - Aliz üzenetet küld Bob-nak
  - nyílt kommunikációs csatornán
  - biztonság
  - **eszköz:** titkosítás
- integritás
  - Aliz üzenetet küld Bob-nak
  - nyílt kommunikációs csatornán
  - autenticitás (hívó-ID, email cím)
  - integritás
  - bármely nem észlelt üzenet-módosítást megakadályoz
  - ellenséges módosítás nem kritpo feladat (fizikai ellenintézkedések)
  - **eszköz:** ???

Titkosítás vs. üzenet autentikáció

- Titkosítás folyamtitkosítóval
  - legyen $c := E_k(m) = G(k) \oplus m$ a titkos szöveg, ahol $G(.)$ egy PRG
  - egy bit megváltoztatása c-ben $\Longrightarrow$ uaz a bit megváltozik m-ben
  - Pl: a 11-ik lsb megváltoztatása 1000$ eltérést okoz...
  - a rendszer ettől még biztonságos...
  - hasonló támadás a one-time pad ellen is...

Titkosítás vs. üzenet autentikáció

- Titkosítás blokktitkosítóval
  - uez a támadás OTR és CTR módban
  - kicsit komplikáltabb támadás ECB és CBC módban
- titkosítás önmagában nem garantál integritást
  - c teljesen elrejti m-et
  - DE a támadó módosíthatja c-t értelmesen!
  - bármely lehetséges c megfelel egy m-nek...
- valami új kell

Üzenet autentikációs kód: definíció

Probléma

- a kommunikáló feleknek van egy közös titkuk (a titkos kulcs)
- autentikált üzenet küldése
- az üzenet módosították-e?
- **Message Authentication Code (MAC)**

Üzenet autentikációs kód: definíció

Definíció

*Egy **üzenet autentikációs kód (MAC)** egy $(Gen, Mac, Vrfy)$ hármas, amire:*

- Gen *a kulcsgenerálás, ami adott* 1^n *biztonsági paraméterre egy* k *titkos kulcsot ad vissza, amire* $|k| \geq n$
- Mac *a címkegenerálás, ami* k *kulcs és* $m \in \{0,1\}^*$ *üzenet esetén egy* t *MAC címkét ad vissza:* $t := Mac_k(m)$
- $Vrfy$ *az ellenőrzés, ami* k *kulcs,* t *címke és* m *üzenet esetén egy* $b := Vrfy_k(m,t)$ *bitet ad visssza, ami* $b = 1$*, ha a* t *érvényes MAC címke* m*-hez és 0 egyébként*

*Továbbá a rendszernek **korrektnek** kell lennie: tetszőleges paraméterekre*

$$Vrfy_k(m, Mac_k(m)) = 1.$$

Üzenet autentikációs kód: biztonság definíció

Hogyan támadjuk ezt a rendszert?

- a támadó az alábbi lépéseket végzi:
  1. valamely üzenetekhez tartozó MAC címkéket kérdez Aliztól (hatás az m tartalmára)
  2. az eredmények alaján számolgat
  3. kiad egy *hamisítványt*: egy érvényes t címkét valamely új m-hez (korábban nem kérdezett)
- biztonságos, ha ez a támadás „nehéz”

Definíció

*Egy autentikációs kód **adaptív választott nyíltszöveges támadás ellen biztonságos** (vagy röviden **biztonságos**), ha minden PPT támadó egy m üzenetre egy érvényes t MAC címkét csak elhanyagolható valószínűséggel tud készíteni több t' címke lekérdezése után $m' \neq m$ üzenetekre.*

Üzenet autentikációs kód: biztonság definíció

Definíció

*Egy autentikációs kód **adaptív választott nyíltszöveges támadás ellen biztonságos** (vagy röviden **biztonságos**), ha minden PPT támadó egy m üzenetre egy érvényes t MAC címkét csak elhanyagolható valószínűséggel tud készíteni több t' címke lekérdezése után $m' \neq m$ üzenetekre.*

- túl erős definíció?
  - támadó bármely üzenet címkéjét lekérdezheti
  - bármely üzenethez tartozó címke generálásával „feltörik” a rendszert
- gyakorlatban csak az értelmes üzenetek érdekesek
- mit jelent az ”értelmes„?
- *Visszajátszásos támadás (Replay attack)*
  - egyéb megoldások: sorozatszámok vagy idő-pecsétek az $m$hez fűzve
  - hátrányok: tárolási vagy szinkronizálási problémák

MAC konstrukció rögzített hosszú üzenetre

Rögzített hosszú MAC

Legyen $PRF : \{0,1\}^n \mapsto \{0,1\}^n$ pszeudovéletlen függvény. Ekkor az alábbi egy rögzített hosszú MAC:

Gen: $k \in_R \{0,1\}^n$

Mac: adott k kulcs és $m \in \{0,1\}^n$ üzenetre a címke $t := PRF_k(m)$

$Vrfy$: adott k kulcsra, $m \in \{0,1\}^n$ üzenetre és $t \in \{0,1\}^n$ címkére az output 1 $\Leftrightarrow t = PRF_k(m)$

MAC konstrukció rögzített hosszú üzenetre

Rögzített hosszú MAC

Legyen $PRF : \{0,1\}^n \mapsto \{0,1\}^n$ pszeudovéletlen függvény.
Ekkor az alábbi egy rögzített hosszú MAC:

Gen: $k \in_R \{0,1\}^n$

Mac: adott k kulcs és $m \in \{0,1\}^n$ üzenetre a címke $t := PRF_k(m)$

$Vrfy$: adott k kulcsra, $m \in \{0,1\}^n$ üzenetre és $t \in \{0,1\}^n$ címkére az output 1 $\Leftrightarrow t = PRF_k(m)$

- ha PRF pszeudovéletlen függvény $\Rightarrow$ biztonságos
- hátrány: csak fix hosszúságú m-re
- randomizálással (+ pár trükkel) kiterjeszthető tetsz. hosszra

MAC blokktitkosítóból

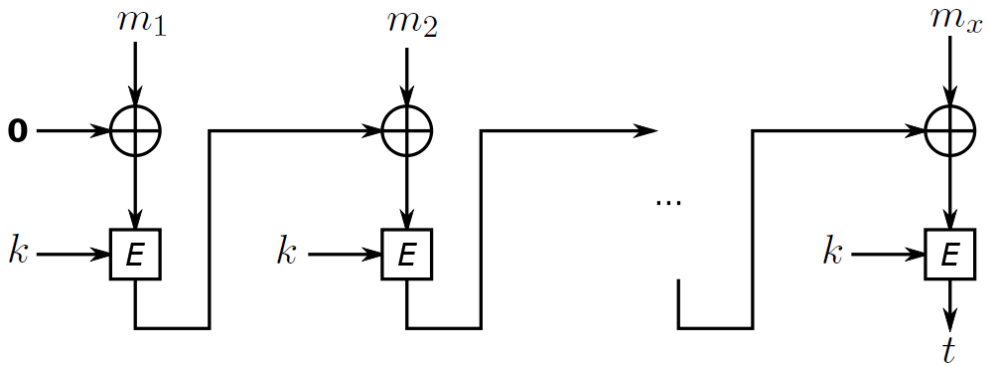
CBC-MAC

Legyen $E_k : \{0,1\}^n \mapsto \{0,1\}^n$ egy blokktitkosító és x fix méret

Gen: $k \in_R \{0,1\}^n$

Mac: adott k kulcsra és
$m = (m_1|m_2|\ldots|m_x), m_i \in \{0,1\}^n$ üzenetre
$i = 1, \ldots, x$ esetén számítsuk ki
$t_i := E_k(t_{i-1} \oplus m_i)$, ahol $t_0 := 0^n$. A címke $t := t_x$

$Vrfy$: Adott k kulcs, $m \in \{0,1\}^{x \cdot n}$ üzenet és $t \in \{0,1\}^n$ címke esetén az output 1 $\Leftrightarrow t = Mac_k(m)$

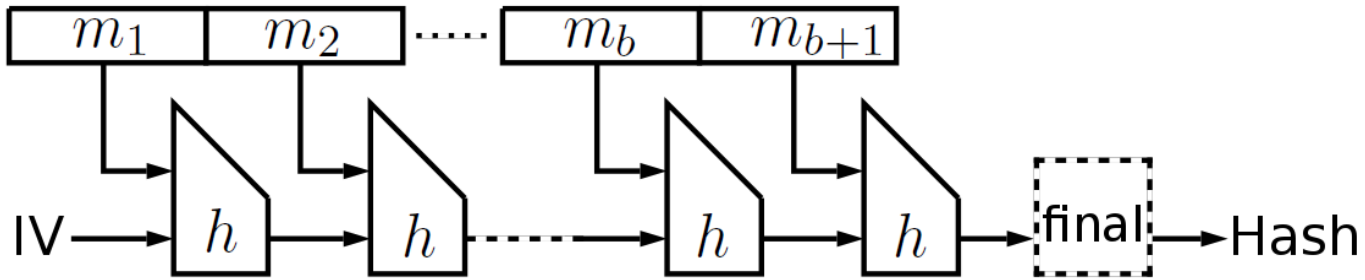


Rögzített hosszúságú CBC-MAC

MAC hash függvényekből

- Ötlet: kulcs-előállítás + hash 2 körben
- Kulcs-előállítás: inner és outer kulcs
- Hash: tetszőleges h kompressziós fv Merkle-Damgård transzformációja (pl. HMAC-SHA1, HMAC-MD5, ...)
- címke: üzenet + kulcsok hash-e

Memo: Merkle-Damgård



MAC hash függvényekből

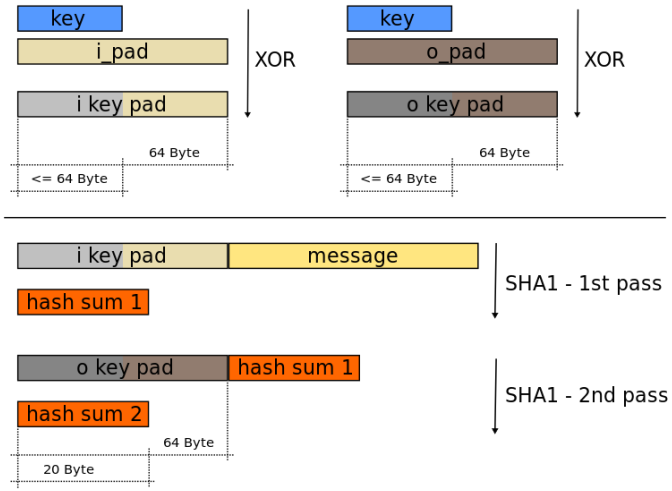
HMAC-h

Legyen h kompressziós fv, H az ebből gyártott Merkle-Damgård hash fv és $ipad, opad \in \{0,1\}^n$ fix

Gen: $k \in_R \{0,1\}^n$

Mac: adott k kulcsra és $m \in \{0,1\}^*$ üzenetre a címke $t := H((k \oplus opad)|H(k \oplus ipad|m))$

$Vrfy$: az output 1 $\Leftrightarrow t = Mac_k(m)$



HMAC-SHA1

MAC hash függvényekből

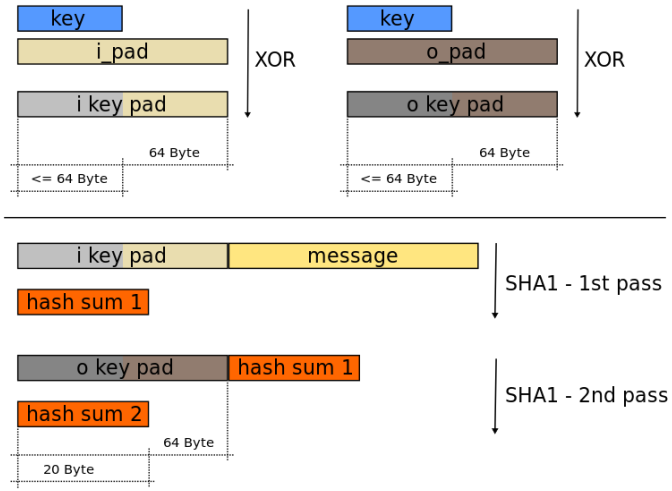
HMAC-h

Legyen h kompressziós fv, H az ebből gyártott Merkle-Damgård hash fv és $ipad, opad \in \{0,1\}^n$ fix

Gen: $k \in_R \{0,1\}^n$

Mac: adott k kulcsra és $m \in \{0,1\}^*$ üzenetre a címke $t := H((k \oplus opad)|H(k \oplus ipad|m))$

$Vrfy$: az output 1 $\Leftrightarrow t = Mac_k(m)$



HMAC-SHA1

- ha h ütközésmentes, akkor biztonságos
- hossz-alapú támadások ellen véd
- eltünteti a h hash-fv gyengeségeit
- SHA-3-ra overkill ($t = SHA-3(k|m)$ elég)
- alkalmazás: IPsec, SSH, TLS, JSON Web token...

Memo: CCA biztonság

Definíció (CCA megkülönböztethetetlenség kísérlet $PrivK^{cca}_{\mathcal{A},\Pi}(n)$)

1. $k = Gen(1^n)$
2. *az $\mathcal{A}$ támadó 1^n inputon orákulumként hozzáfér $Enc_k(.)$-hez és $Dec_k(.)-$hez, majd kiad m_0, m_1 üzeneteket, amire $|m_0| = |m_1|$*
3. $b \in_R \{0,1\} : c = Enc_k(m_b)$ *ezt megkapja $\mathcal{A}$*
4. *$\mathcal{A}$ ismét orákulumként hozzáfér $Enc_k(.)$-hez és $Dec_k(.)-$hez, kivéve $Dec_k(c)$-t, majd kiad $b' \in \{0,1\}$*
5. $PrivK^{cca}_{\mathcal{A},\Pi}(n) = 1$, *ha $b = b'$, és 0 egyébként*

Memo: CCA biztonság

Definíció

Egy $\Pi = (Gen, Enc, Dec)$ *titkosítás* ***megkülönböztethetetlen választott titkosszöveges támadás esetén (CCA-biztonságos)****, ha* $\forall \mathcal{A}$ *PPT támadóra* $\exists e(.)$ *elhanyagolható függvény, amire*

$$P(PrivK^{cca}_{\mathcal{A},\Pi}(n) = 1) \leq \frac{1}{2} + e(n).$$

Memo: CCA biztonság

Definíció

Egy $\Pi = (Gen, Enc, Dec)$ *titkosítás* ***megkülönböztethetetlen választott titkosszöveges támadás esetén (CCA-biztonságos)****, ha* $\forall \mathcal{A}$ *PPT támadóra* $\exists e(.)$ *elhanyagolható függvény, amire*

$$P(PrivK^{cca}_{\mathcal{A},\Pi}(n) = 1) \leq \frac{1}{2} + e(n).$$

- korábbi konstrukciók nem teljesítik
- ötlet: titkosítás + MAC kombó
  - $\Pi_E = (Gen_E, Enc, Dec)$ titkosítás az m védelmére
  - $\Pi_M = (Gen_M, Mac, Vrfy)$ MAC a c módosítása ellen
- kérdés: hogyan kombináljuk?

CCA biztonságos konstrukció

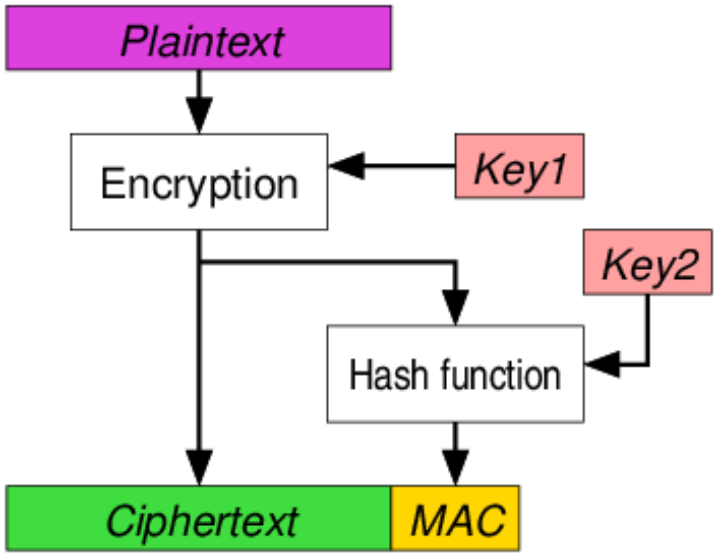
Encrypt-then-MAC

Adott Π_E és Π_M. Ekkor Π_{EtM}:

Gen: $k_E = Gen_E(1^n), k_M = Gen_M(1^n)$

Enc: adott k_E, k_M kulcsokra és $m \in \{0,1\}^*$ üzenetre a titkosszöveg (c,t), ahol $c := Enc_{k_E}(m), t := Mac_{k_M}(c)$

Dec: ha $Vrfy_{k_M}(c,t) = 1$, akkor $m = Dec_{k_E}(c)$



CCA biztonságos konstrukció

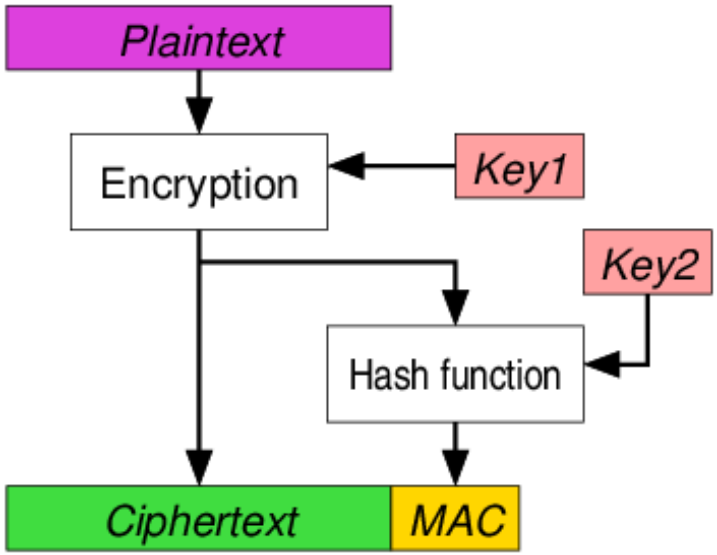
Encrypt-then-MAC

Adott Π_E és Π_M. Ekkor Π_{EtM}:

Gen: $k_E = Gen_E(1^n), k_M = Gen_M(1^n)$

Enc: adott k_E, k_M kulcsokra és $m \in \{0,1\}^*$ üzenetre a titkosszöveg (c,t), ahol $c := Enc_{k_E}(m), t := Mac_{k_M}(c)$

Dec: ha $Vrfy_{k_M}(c,t) = 1$, akkor $m = Dec_{k_E}(c)$



- ha Π_E CPA-bizt és Π_M bizt $\Rightarrow$ Π_{EtM} CCA-bizt
- k_E és k_M függetlensége kritikus!

CCA biztonságos (?) konstrukció

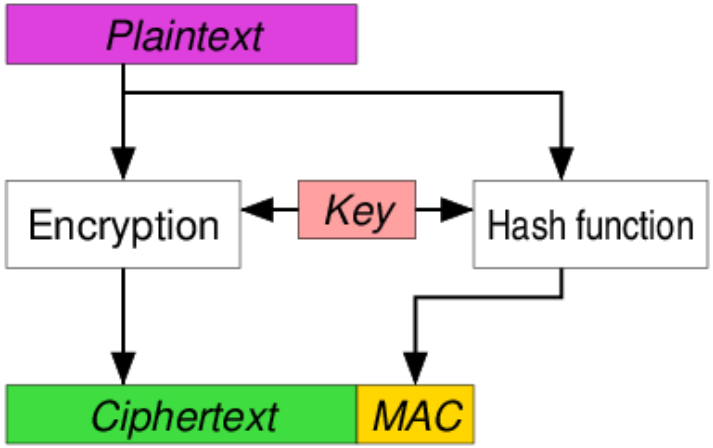
Encrypt-and-MAC

Adott Π_E és Π_M. Ekkor $\Pi_{E\&M}$:

Gen: $k_E = Gen_E(1^n), k_M = Gen_M(1^n)$

Enc: adott k_E, k_M kulcsokra és $m \in \{0,1\}^*$ üzenetre a titkosszöveg (c,t), ahol $c := Enc_{k_E}(m), t := Mac_{k_M}(m)$

Dec: $m = Dec_{k_E}(c)$, ha $Vrfy_{k_M}(m,t) = 1$



CCA biztonságos (?) konstrukció

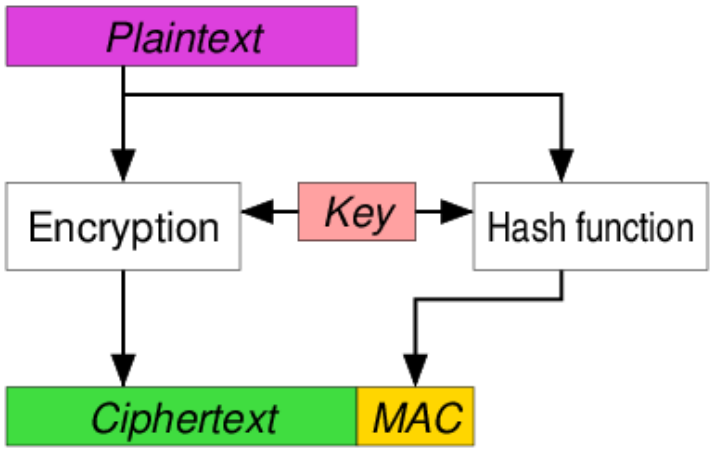
Encrypt-and-MAC

Adott Π_E és Π_M. Ekkor $\Pi_{E\&M}$:

Gen: $k_E = Gen_E(1^n), k_M = Gen_M(1^n)$

Enc: adott k_E, k_M kulcsokra és $m \in \{0,1\}^*$ üzenetre a titkosszöveg (c, t), ahol $c := Enc_{k_E}(m), t := Mac_{k_M}(m)$

Dec: $m = Dec_{k_E}(c)$, ha $Vrfy_{k_M}(m, t) = 1$



- mint Π_{EtM}, kivéve a címke: $t := Mac_{k_M}(m)$
- baj: t címke és m üzenet nem feltétlenül független
- ha a Mac determinisztikus (pl. CBC-MAC), akkor t-ből kiderülhet, ha uazt az m van többször titkosítva

CCA biztonságos (?) konstrukció

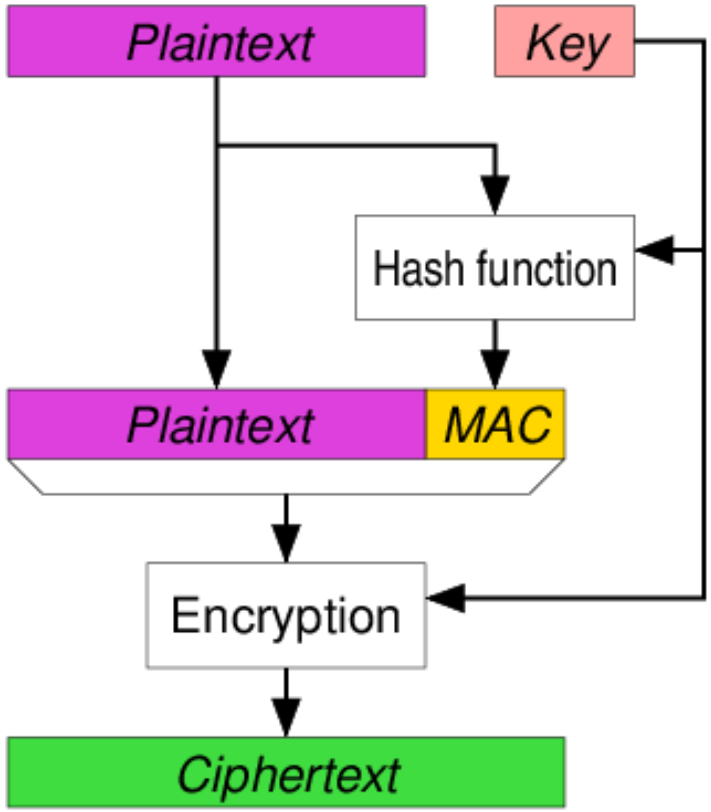
Mac-then-Encrypt

Adott Π_E és Π_M. Ekkor Π_{MtE}:

Gen: $k_E = Gen_E(1^n), k_M = Gen_M(1^n)$

Enc: adott k_E, k_M kulcsokra és $m \in \{0,1\}^*$ üzenetre a titkosszöveg (t, c), ahol $t := Mac_{k_M}(m), c := Enc_{k_E}(m|t)$

Dec: $(m|t) = Dec_{k_E}(c)$, ha $Vrfy_{k_M}(m,t) = 1$



CCA biztonságos (?) konstrukció

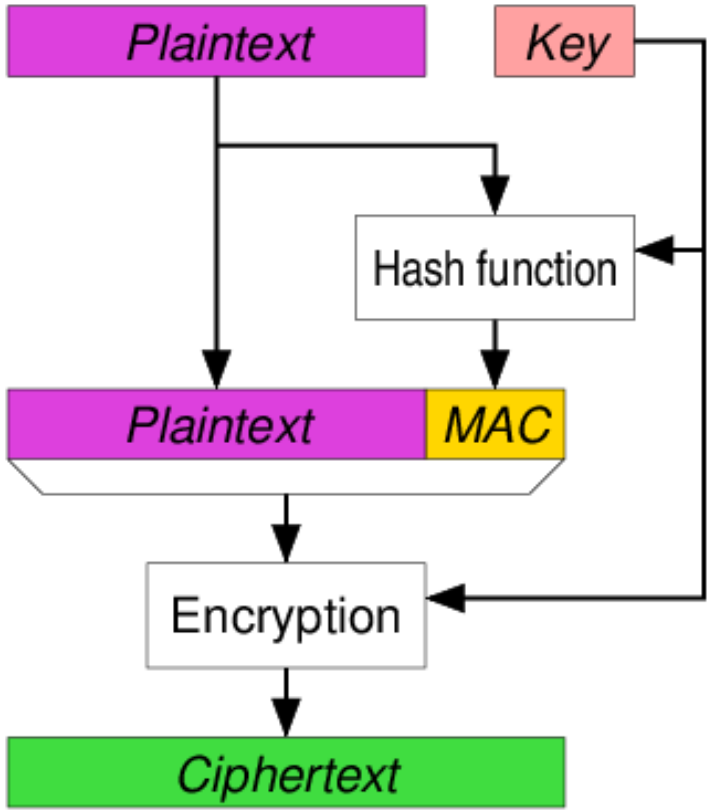
Mac-then-Encrypt

Adott Π_E és Π_M. Ekkor Π_{MtE}:

Gen: $k_E = Gen_E(1^n), k_M = Gen_M(1^n)$

Enc: adott k_E, k_M kulcsokra és $m \in \{0,1\}^*$ üzenetre a titkosszöveg (t, c), ahol $t := Mac_{k_M}(m), c := Enc_{k_E}(m|t)$

Dec: $(m|t) = Dec_{k_E}(c)$, ha $Vrfy_{k_M}(m,t) = 1$



- először t címke, ez titkosítva az üzenettel együtt
- baj: ha a Π_E blokktitkosító CBC-módban, akkor támadható (padding-oracle attack)
- IPsec, TLS 1.0 elleni támadások

Biztonság + Integritás

- biztonságos kommunikáció
  - **eszköz:** titkosítás
- integritás
  - **eszköz:** MAC
- lehet mind2?

Biztonság + Integritás

- biztonságos kommunikáció
  - **eszköz:** titkosítás
- integritás
  - **eszköz:** MAC
- lehet mind2?

Autentikált titkosítás

- cél: biztonság ÉS integritás elérése egyszerre
- probléma: hogyan kombináljuk az eszközöket?
- megoldások:
  - Encrypt-then-MAC
  - SHA-3 szivacs-konstrukció duplex módban
  - AES-128 Galois-CTR módban

Ma is tanultam valamit

Összegzés

- Biztonság vs. integritás
- (H)MAC
- Nem mindegy, hogyan illesztjük össze az építőkockákat
- CCA-biztonságos konstrukció MAC-ből